SOC THEORETICAL KNOWLEDGE REPORT

Document Version: 2.0

Document Information

Item	Details
Assessment Type	SOC Theoretical Knowledge Assessment – Alert Prioritization, Incident Classification & Incident Response
Frameworks & Standards Referenced	CVSS v3.1, NIST SP 800-61, MITRE ATT&CK, ENISA Taxonomy, VERIS Framework
Scope	Theoretical understanding of SOC operations and standardized security handling methodologies
Report Prepared By	Pal Piyushkumar Patel
Date	03-03-2026

Introduction

In modern cybersecurity environments, Security Operations Centers (SOCs) serve as the frontline defense against cyber threats. Effective SOC operations depend heavily on three foundational competencies:

1. **Alert Priority Levels**
2. **Incident Classification**
3. **Basic Incident Response**

This report provides an in-depth theoretical explanation of these domains, aligned with globally recognized standards and frameworks.

Intended Audience:

- SOC Analysts (Tier 1 / Tier 2)
- Incident Responders
- Security Engineers
- Cybersecurity Students

Purpose:
To develop structured knowledge required to assess alerts, classify incidents accurately, and execute systematic response procedures in enterprise environments.

1. Alert Priority Levels

1.1 Overview

Alert prioritization is the process of determining the urgency and importance of a security alert. SOC teams typically receive thousands of alerts daily; without structured prioritization, teams may waste time on low-risk events while critical incidents escalate unnoticed.

Alert priority is determined using the following risk-based formula:

Risk = Impact × Likelihood × Asset Criticality

This ensures that decisions are based on business impact rather than just technical severity.

1.2 Understanding Severity vs Priority

It is essential to distinguish between severity and priority.

Term	Definition
Severity	Technical impact of a vulnerability or attack
Priority	Urgency assigned by the SOC based on business context

Example:

- A CVSS 9.0 vulnerability on a test server → High Severity, Medium Priority
- A CVSS 6.5 brute-force attack on a CEO account → Medium Severity, High Priority

Priority always considers business context.

1.3 Priority Definitions in SOC

Most organizations classify alerts into four levels:

Critical (P1)

- Active ransomware encryption
- Confirmed data exfiltration
- Domain administrator compromise
- Exploited internet-facing vulnerability

High (P2)

- Unauthorized admin access
- Malware beaconing to command-and-control (C2)
- Privilege escalation attempts

Medium (P3)

- Multiple failed login attempts

- Suspicious PowerShell execution
- Unusual outbound traffic

Low (P4)

- Blocked phishing email
- Informational log events
- Policy violations without compromise

1.4 CVSS (Common Vulnerability Scoring System)

Developed by:
FIRST

CVSS provides standardized risk quantification for vulnerabilities.

CVSS Metrics

Base Metrics

- Attack Vector (Network / Local)
- Attack Complexity
- Privileges Required
- User Interaction
- Confidentiality Impact
- Integrity Impact
- Availability Impact

Temporal Metrics

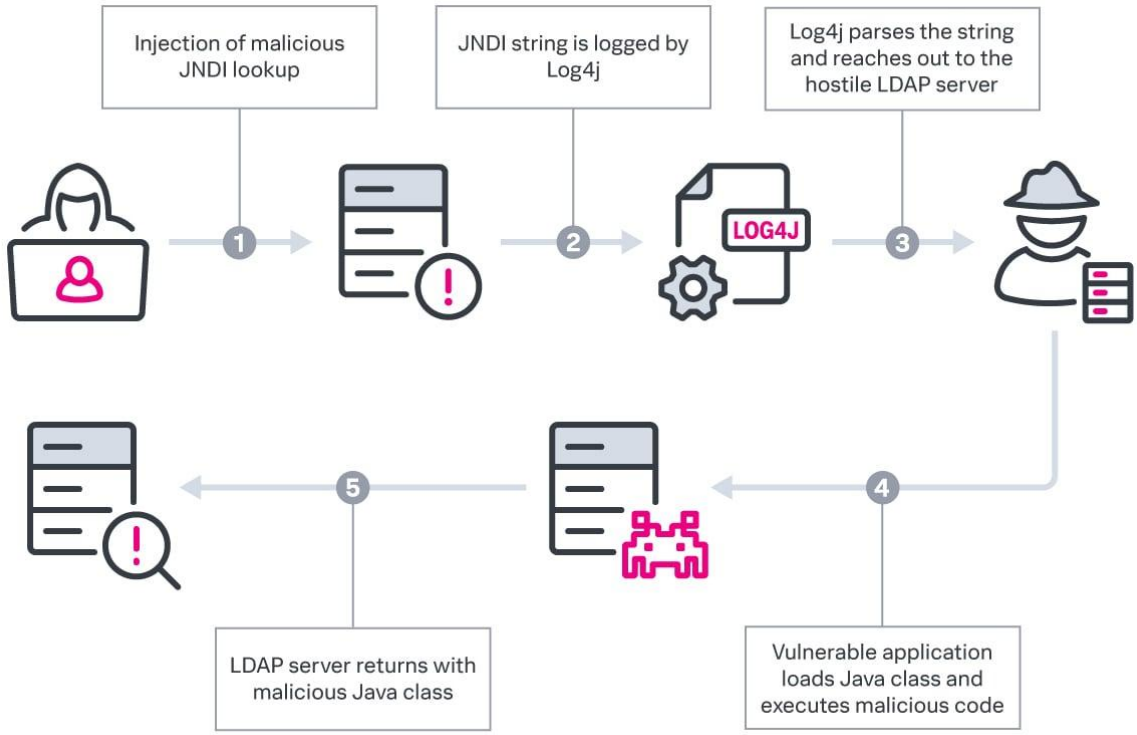
- Exploit code maturity
- Remediation level
- Report confidence

Environmental Metrics

- Asset importance
- Security controls in place

Case Study: Log4Shell

CVE-2021-44228



Technical Impact:

- Remote Code Execution
- No authentication required
- Network exploitable
- Widespread exposure

CVSS Score: 9.8 (Critical)

SOC Priority: Critical (P1)

Reason:

- Public exploit availability
- Active exploitation globally
- High asset exposure risk
- Potential full infrastructure compromise

1.5 Asset Criticality in Priority Assignment

Priority is heavily influenced by the importance of the affected asset.

Asset Type	Example Priority
Domain Controller	Critical
Production Database	Critical
HR Workstation	High
Test Server	Medium
Retired System	Low

Questions analysts must ask:

- Does this system generate revenue?
- Does it store PII?
- Is it publicly accessible?
- Is it privileged infrastructure?

1.6 Risk-Based Alerting in SOC Tools

Example SIEM platform:
Splunk Enterprise Security

Modern SOC tools use:

- User risk scoring
- Asset risk scoring
- Threat intelligence integration
- Behavioral anomaly detection

These tools dynamically adjust alert priority based on contextual risk.

2. Incident Classification

2.1 Overview

Incident classification ensures standardized documentation, reporting, and investigation.

Proper classification allows:

- Accurate reporting
- Trend identification
- Threat intelligence sharing
- Compliance alignment

2.2 Incident Categories

Common SOC categories include:

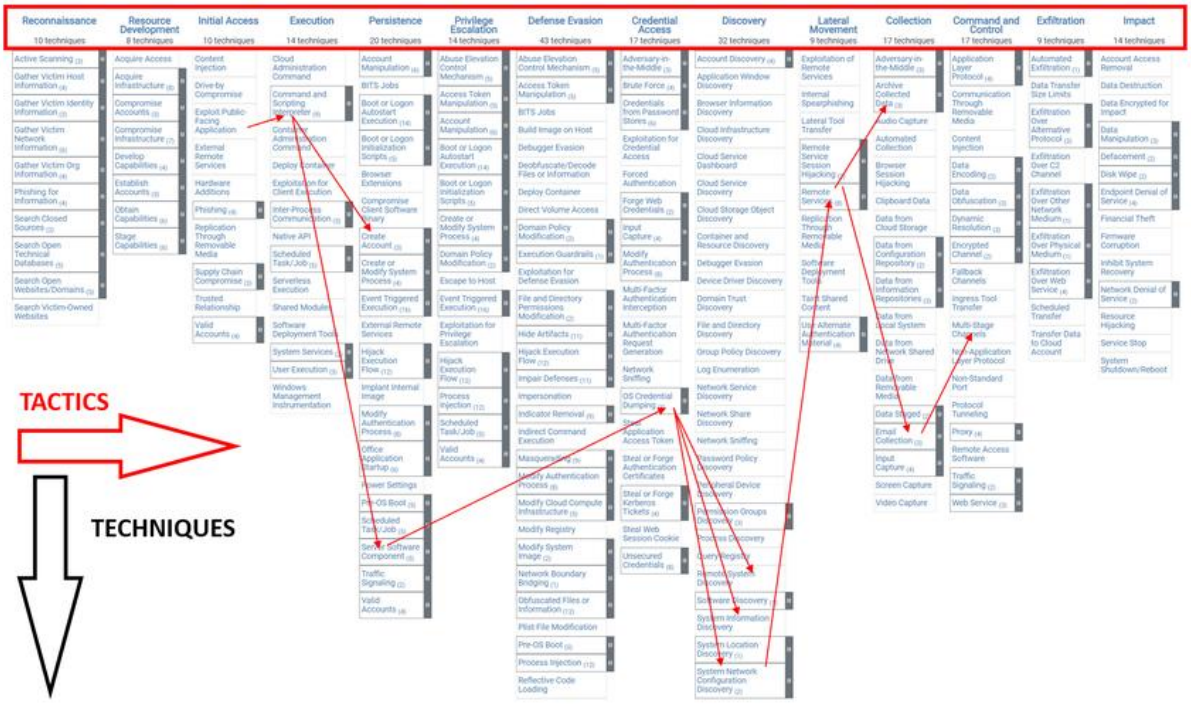
- Malware
- Phishing
- DDoS
- Insider Threat
- Data Exfiltration
- Credential Compromise
- Unauthorized Access

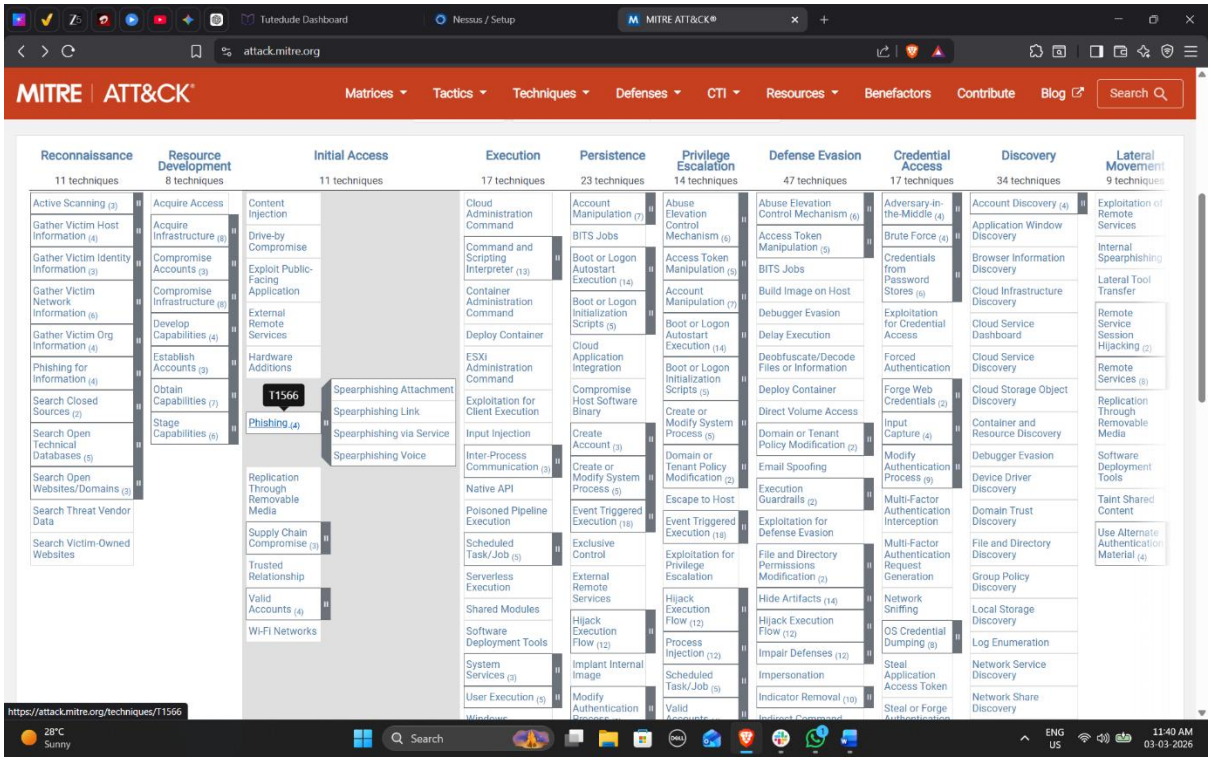
Example:
An employee exporting confidential files → Insider Threat

2.3 MITRE ATT&CK Framework

Developed by:
MITRE Corporation

Framework:
MITRE ATT&CK





Example Mapping:

Incident: Phishing Email
Technique: T1566 – Phishing
Tactic: Initial Access

Benefits:

- Standardized terminology
- Enhanced reporting clarity
- Detection gap analysis

2.4 ENISA and VERIS Taxonomy

- ENISA Incident Taxonomy
- VERIS

VERIS helps structure incidents into:

- Actor
- Action
- Asset
- Attribute

This improves consistency in breach reporting.

2.5 Contextual Metadata

Every classified incident must include:

- Date and Time
- Source and Destination IP
- Affected systems
- User accounts involved
- Hash values
- Indicators of Compromise (IOCs)

Example:

Type: Malware
Technique: Command & Control
Hash: SHA256: XXXXX
Impact: Finance server compromise

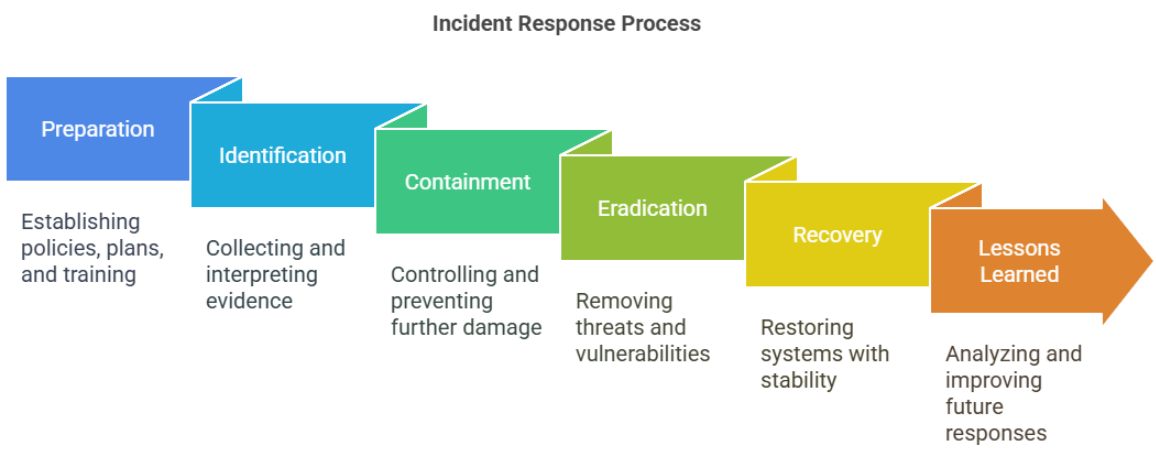
3. Basic Incident Response

3.1 Overview

Incident response minimizes damage, restores operations, and strengthens defenses.

Primary reference:
NIST SP 800-61

3.2 Incident Response Lifecycle



1. Preparation

- Develop playbooks
- Train staff
- Enable logging
- Conduct tabletop exercises

2. Identification

- Validate alerts
- Confirm compromise
- Scope affected systems

3. Containment

- Short-term containment (isolate host)
- Long-term containment (patch systems)

4. Eradication

- Remove malware
- Patch vulnerabilities
- Reset credentials

5. Recovery

- Restore systems
- Monitor for recurrence

6. Lessons Learned

- Root cause analysis
- Improve detection rules
- Update policies

3.3 Evidence Preservation

Proper handling includes:

- Memory capture
- File hashing (SHA256)
- Log preservation
- Chain of custody documentation

Evidence integrity must never be compromised.

3.4 SOAR Automation

Example automation platform:
Splunk Phantom

Capabilities:

- Automatic endpoint isolation
- IP blocking
- Ticket generation
- Escalation workflows

Automation reduces response time and human error.

Conclusion

Alert prioritization, incident classification, and structured incident response form the core of SOC operations.

Mastery ensures:

- Faster detection
- Accurate reporting
- Reduced business impact
- Stronger organizational resilience

Theoretical understanding combined with continuous practice prepares analysts for real-world enterprise security challenges.

References

- FIRST – CVSS Documentation
- NIST SP 800-61 – Incident Handling Guide
- MITRE ATT&CK Framework
- ENISA Incident Taxonomy
- VERIS Framework
- CISA Security Advisories